

[IOC (Indicators of Compromise) - SOC L1 Core Notes]

[What is IOC?]

An IOC (Indicator of Compromise) is a piece of digital evidence that shows a system, network, or account may have been attacked or compromised by a threat actor.

"IOC is a clue or evidence that helps security teams identify a cyber attack."

SOC analysts use IOCs to:

- Detect cyber attacks
- Investigate incidents
- Identify malicious behavior
- Block threats quickly
- Search for infected systems

Initial Quick Examples: Malicious IP address, Suspicious domain, Malware file hash, Phishing email sender, Unusual login activity.

[Why IOCs Are Important]

IOCs help SOC analysts detect attacks faster, investigate incidents comprehensively, prevent further infrastructural damage, hunt threats proactively inside networks, and consistently improve SIEM detection alerts.

[Common Types of IOCs]

```
[ Indicators of Compromise (IOC) ]
├── Network-Based Indicators
│   ├── 1. IP Address (e.g., 185.220.101.45)
│   ├── 2. Domain IOC (e.g., micr0soft-login[.]com)
│   ├── 3. URL IOC (e.g., http://fake-update-download.com/install.exe)
│   └── 4. Network Traffic (Large outbound bytes, C2 callbacks)
└── Host-Based Indicators
    ├── 5. File Hash (MD5, SHA1, SHA256)
    ├── 6. File Name (e.g., invoice.exe, payload.ps1)
    ├── 7. Registry Keys (Windows Persistence Path modifications)
    └── 8. Process Anomalies (e.g., powershell.exe -enc)
```

[1. IP Address IOC]

Attackers often use malicious IP addresses. SOC analysts check: Source IP, Destination IP, Geolocation, and Reputation.

Detection Example: Multiple failed logins from a single suspicious IP address context.

[2. Domain IOC]

Attackers create fake domains for phishing or malware infrastructure delivery (e.g., micr0soft-login[.]com). Used in phishing attacks, malware communication, and fake landing login pages.

[3. URL IOC]

Malicious URLs are explicitly designed to download malware payloads, steal user credentials via web-injects, or redirect users (e.g., `http://fake-update-download.com/install.exe`).

[4. File Hash IOC]

A unique cryptographic identifier for binary data (MD5, SHA1, SHA256). SOC analysts match hashes using tool matrices like VirusTotal, Threat intelligence feeds, and automated EDR solutions.

[5. Email IOC]

Phishing campaigns contain specific traceable indicators such as a suspicious sender address (e.g., `support-paypal-security@gmail.com`), malicious attachment wrappers, cloned domains, and bad links.

[6. File Name IOC]

Attackers camouflage malicious execution strings inside misleading names: `invoice.exe`, `update.bat`, or `payload.ps1`.

[7. Registry IOC (Windows)]

Malware modifies Windows software keys to establish persistent survival across reboots. Example target path: `HKCU\Software\Microsoft\Windows\CurrentVersion\Run`.

[8. Process IOC]

Suspicious running processes or arguments indicating live malware execution. Examples: `powershell.exe -enc` or hidden binary execution via `cmd.exe /c`.

[9. Network Traffic IOC]

Abnormal transport behavior: massive unauthorized outbound traffic volumes, connection handshakes to unknown geo-locations, or beacons to Command & Control (C2) servers.

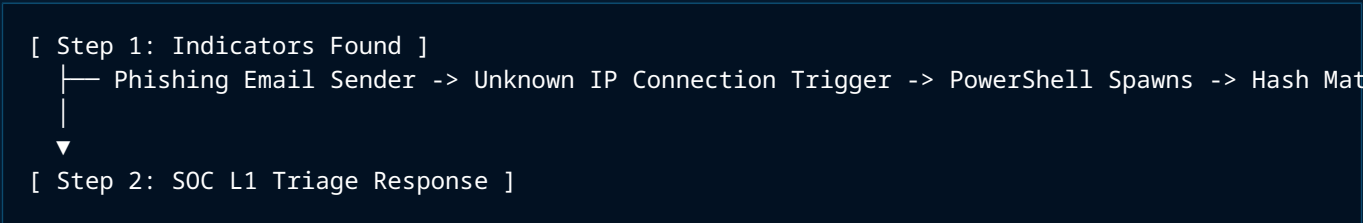
[IOC vs IOA]

Understanding the exact division between proactive and reactive indicators:

IOC (Indicator of Compromise)	IOA (Indicator of Attack)
Shows attack has already happened .	Shows active attack behavior in real-time.
Evidence-based data blocks.	Behavior-based context blocks.
Reactive posture.	Proactive posture.
<i>Example:</i> A known malicious file SHA256 hash or IP.	<i>Example:</i> PowerShell executing an obfuscated script command.

[Real-Life IOC Scenario & Workflow]

Incident Scenario: An employee receives an active phishing delivery vector.



- └─ 1. Block Attacker Source IP at Firewall
- └─ 2. Isolate the Infected System from Network Segment
- └─ 3. Eradicate Malware Binary via EDR tool
- └─ 4. Update SIEM Detection Rules with new Signatures

[Ecosystem: Sources, Tools & SIEM Context]

[IOC Collection Sources]

SOC teams collect actionable intelligence indicators via Threat intelligence feeds, VirusTotal queries, native SIEM alerts, active EDR tools, central firewall traffic logs, Antivirus definitions, and OSINT frameworks.

[IOC Tools Matrix]

Tool Name	Operational Use Case
Wireshark	Deep network packet analysis and session rebuilding.
Splunk	Centralized enterprise log monitoring and parsing repository.
VirusTotal	Rapid Hash, IP, URL, and Domain structural reputation checking.
CrowdStrike	Endpoint detection, host isolation, and live inspection.
Microsoft Defender	Enterprise threat detection and automated alert compilation.
Snort / Suricata	Network-based Intrusion Detection Systems (IDS) packet rules monitoring.

[SIEM Alert Example: Suspicious PowerShell]

SIEM string matching on: powershell.exe -EncodedCommand. This pattern directly alerts the L1 analyst to look for malware payload execution, fileless malicious runtime scripts, or advanced script evasion tactics.

[IOC Lifecycle]

```
[ 1. Detection ] —> [ 2. Analysis ] —> [ 3. Containment ]
                                     |
                                     ▼
[ 6. Documentation ] <— [ 5. Recovery ] <— [ 4. Eradication ]
```

1. Detection: Identify anomalous signatures or behaviors within systems.
2. Analysis: Verify whether the flag or IOC represents true malicious intent.
3. Containment: Block network communication or isolate affected endpoints immediately.
4. Eradication: Completely purge malware elements and wipe attacker backdoors.
5. Recovery: Restore operational workloads back to production safely.
6. Documentation: Compile comprehensive incident summaries and lessons learned reports.

[Comprehensive Quick Reference Categories]

Category	Indicator Example
IP Address	192.168.1.10 (or external threat vector IP)
Domain	fakebank-login.com
URL	malicious-site.com/payload
Hash	SHA256 signature code matches
Email	attacker@gmail.com / domain spoofer
Process	powershell.exe running hidden arguments
Registry	Run key registry persistence insertions
File Name	invoice.exe / updates string variants

Note on Threat Hunting & False Positives: Threat hunters actively use these parameters to sweep all organization endpoints for a target hash. However, analysts must be cautious of **False Positives**, such as a legitimate system administrator executing clean internal scripts, or automated vulnerability assessment tools simulating baseline network noise.

[Interview Preparation: Questions & Answers]

Q1. What is an IOC?

Answer: An IOC (Indicator of Compromise) is digital forensic evidence indicating that an infrastructure asset or user account has been successfully breached or subjected to malicious activity.

Q2. Give core examples of typical IOCs.

Answer: Core indicators include hostile IP addresses, malicious domains, payload download URLs, file hashes (MD5/SHA256), spear-phishing email metadata, and anomalous shell processes.

Q3. What is the fundamental difference between an IOC and an IOA?

Answer: An IOC acts as a reactive post-compromise digital footprint (evidence that an attack has already occurred). An IOA focuses on active runtime behavior patterns (identifying an ongoing attack attempt in real-time).

Q4. Which technical tools are used by analysts to hunt and analyze IOCs?

Answer: Analysts leverage central SIEM platforms like Splunk, deep capture packet analysis tools like Wireshark, online verification indexes like VirusTotal, and EDR suites like CrowdStrike or Microsoft Defender.